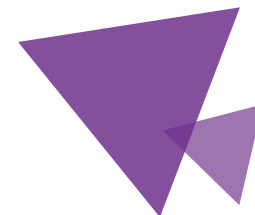




南京邮电大学
Nanjing University of Posts and Telecommunications



低功耗蓝牙协议安全



答辩人：1025040924 欧阳庆



目录

CONTENT



基础内容
Basic Content



工作流程
Workflow



安全问题
Security Issue



总结展望
Summary and Outlook



南京邮电大学
Nanjing University of Posts and Telecommunications

第一部分

低功耗蓝牙：Bluetooth Low Energy，简称BLE

主要特点是：在保持无线通信能力的同时，尽可能降低设备耗电量。



智能手环



智能门锁



共享单车开锁

⚡ 协议对比

对比点	传统蓝牙	BLE
主要用途	音频、文件传输	传感器、控制、短数据传输
功耗	较高	很低
数据量	较大	较小
连接时间	相对较长	可以快速连接
应用场景	耳机、音箱、车载蓝牙	手环、门锁、传感器

BLE面临的挑战

1. 新型安全漏洞持续涌现，设备整体安全风险突出
2. 协议版本与平台差异大，设备互操作性不足
3. 2.4GHz频段干扰严重，功耗、性能与安全难以兼顾
4. 大规模运维难度高，同时面临严格的合规监管要求

BLE安全的重要性

1. 守护用户隐私，防止各类敏感数据泄露
2. 防范设备被恶意操控，保障人身与财产安全
3. 保证通信数据完整可靠，杜绝篡改与伪造
4. 满足行业合规要求，维系物联网生态信任



南京邮电大学
Nanjing University of Posts and Telecommunications

第二部分

BLE工作流程



主设备：可以发起对从设备的扫描连接，例如手机
从设备：只能广播等待主机的连接，例如智能手环

⚡ BLE配对



南京邮电大学
Nanjing University of Posts and Telecommunications

BLE配对是设备依托**SMP安全管理协议**，在建立无线连接后完成**身份校验、密钥协商、权限分配**的交互流程。

★ 配对的核心作用

1. 核验设备身份
2. 协商加密密钥
3. 划分访问权限
4. 绑定设备密钥



配对方式

Just Works (直接配对)

特点:

用户无需输入密码

操作简单

体验最好



常用场景:

廉价传感器

简单智能家居设备

简易无线外设

配对方式

| Passkey Entry (密码输入)

特点:

双端交互

防被动监听

安全性中等偏高



常用场景:

智能手表

手机和带显示屏设备配对

工业设备配置

配对方式



Numeric Comparison (数字比较)

特点:

数字比对确认

安全级别高

需屏幕显示



常用场景:

手机与手机

手机与带屏设备

智能终端设备



配对方式

Out of Band (带外配对)

特点:

外设传输密钥

碰一碰即配对

安全等级最高



常用场景:

智能门锁

支付设备

车钥匙

⚡ 配对方式对比

配对方式	用户操作	安全性	适用设备
Just Works	几乎无操作	较低	简单传感器、低成本设备
Passkey Entry	输入数字密码	中等	手表、工业终端
Numeric Comparison	双方确认数字	较高	手机、带屏设备
OOB	NFC/二维码	较高	门锁、车钥匙、支付设备

⚡ 配对密钥



密钥名称	作用	生存周期
TK(Temporary Key)	临时密钥，用户保护配对过程	单次配对
LTK(Long Term Key)	长期密钥，用于加密后续所有通信	持久存储直到解绑
IRK(Identity Resolving Key)	用于解析随机地址，保护隐私	持久存储



南京邮电大学
Nanjing University of Posts and Telecommunications

第三部分

场景一：智能门锁常使用BLE实现手机近距离开锁

可能存在的问题：

1. 弱配对机制

如果门锁使用Just Works配对，攻击者可尝试冒充手机或门锁

2. 重放攻击

如果开锁指令每次都差不多，攻击者可截获后再次发送

3. App认证逻辑不严

如果开锁权限主要依赖APP本地判断，可能会被绕过

4. 固件更新不安全

如果门锁允许未经验证的固件升级，可能被植入恶意程序

场景二：智能手环通过BLE与手机同步健康数据

1. 健康数据泄露

如果数据传输未加密，附近攻击者可能监听敏感信息

2. 设备身份暴露

如果设备长期使用固定蓝牙地址，可能被追踪位置

可能存在的 安全问题

3. 未授权读取

如果某些 GATT 特征没有权限控制，陌生设备可能读取数据

4. 假设备钓鱼

攻击者可能伪造同名手环，引导用户连接

场景三：BLE用于血压计、血糖仪、体温计等设备

可能存在的安全漏洞

1. **医疗数据被窃听**：通信未加密，可能导致隐私泄露
2. **数据被篡改**：错误数据可能影响医生或用户的判断
3. **设备冒充**：攻击者可能伪装成医疗设备上传假数据
4. **默认配置不安全**：部分设备为方便连接，默认不开启强认证



南京邮电大学
Nanjing University of Posts and Telecommunications

第四部分

BLE安全问题



BLE常见安全风险

1. 配对阶段风险

- 使用Just Works导致认证不足
- 用户忽略配对提示
- 假设备诱导连接

2. 通信阶段风险

- 数据未加密
- 重放历史指令
- 敏感特征权限设置不当

3. 隐私风险

- 固定蓝牙地址被长期追踪
- 广播包暴露设备类型或用户信息

4. 设备管理风险

- 固件无法更新
- 固件升级未签名
- 默认配置不安全

如何提升BLE设备安全性？

对设备厂商：

1. 默认启用安全配对
2. 敏感数据必须加密
3. 固件升级使用数字签名
4. 提供长期安全更新

对用户：

1. 不连接陌生蓝牙
2. 配对时注意设备名称和提示
3. 定期更新APP和设备固件
4. 丢失设备后及时解绑

低功耗蓝牙近年来在传输速率、定位精度和安全性上都有着颠覆性的突破，以下是当前BLE前沿的技术与研究方向：

1. 蓝牙6.0信道探测

2. 物理层指纹识别

3. 后量子加密算法

4. 低功耗音频广播

⚡ 未来发展趋势



南京邮电大学
Nanjing University of Posts and Telecommunications

1. 更低功耗
2. 更高精度定位
3. 更强安全性
4. 更大规模组网
5. 与边缘计算结合
6. 与AI安全结合



感谢聆听

